

WEBSITE AUDIT REPORT

Amaal Sahari — Facility Management Website

Prepared: March 9, 2026

Summary

This report identifies issues discovered during a full audit of the Amaal Sahari website. Each issue is rated by severity so you can prioritize what to fix first.

■ 5 Critical

■ 4 Major

■ 5 Moderate

■ 4 Minor

CRITICAL — Immediate Attention Required

CRITICAL 1. Admin Pages Have No Real Security

What this means: Anyone on the internet can modify your website content, upload files, or delete data — without logging in. The login page only hides the admin panel visually but does not actually protect the data behind it.

Details:

- The content editing API accepts changes from anyone, no login required.
- The file upload endpoint allows anyone to upload files to your server.
- An attacker could replace your website text, images, or inject harmful content.

Recommendation: Add real server-side security so that only logged-in administrators can make changes.

CRITICAL 2. Default Admin Password Is Known

What this means: The admin password "amaal2024" is written directly in the website code. Anyone who views the code can see it and log into your admin panel.

Details:

- The default password is visible in the source code that browsers download.
- Even if you changed the password, the default one is still visible in the code.
- Automated bots regularly scan websites for known default passwords.

Recommendation: Remove the hardcoded password from the code and require a secure password to be set during first-time setup.

CRITICAL**3. Admin Password Stored Insecurely in Browser**

What this means: After logging in, your password is saved in plain text inside the browser. Any malicious script or browser extension could read it.

Details:

- The password is stored in the browser's localStorage, which is not secure.
- Third-party scripts (analytics, ads, etc.) running on the page can access it.
- If someone gains access to the browser, they immediately have the admin password.

Recommendation: Use secure session tokens (cookies with proper security flags) instead of storing passwords in the browser.

CRITICAL**4. Password Reset Bypasses Email Verification**

What this means: When email is not configured, the password reset system reveals the secret token directly, allowing anyone to reset the admin password without email access.

Details:

- The reset token is returned in the API response when SMTP is not set up.
- An attacker can use this token to set a new admin password.
- This completely bypasses the email verification security step.

Recommendation: Never expose reset tokens in API responses. Disable password reset when email is not configured.

CRITICAL**5. Diagnostic Pages Expose Server Details**

What this means: Several publicly accessible pages reveal detailed information about your server — file paths, disk space, software versions, and email configuration. This information helps attackers plan attacks.

Details:

- The /api/diagnose endpoint shows server paths, permissions, and disk usage.
- The /api/auth/smtp-diagnostic endpoint reveals email server configuration.
- The /api-health page provides a full diagnostic dashboard to anyone.
- These are essentially a map of your system for anyone who finds them.

Recommendation: Remove these diagnostic endpoints entirely, or protect them behind admin authentication.

MAJOR — Broken Functionality

MAJOR**6. All Website Images Are Missing**

What this means: None of the images on the website are loading. Visitors see broken image icons instead of your service photos, case studies, and branding images.

Details:

- The image files folder (public/) does not exist on the server.
- Over 20 different images are referenced but none are available.
- This affects the homepage, services, case studies, and about pages.
- The website appears unprofessional and incomplete without images.

Recommendation: Upload all required images to the server, or update the website to use images from an external storage service.

MAJOR**7. Contact Form Does Not Send Messages**

What this means: When visitors fill out the contact form, their message is only saved in their own browser — it is never sent to you. You are not receiving any customer inquiries submitted through the website.

Details:

- Form submissions are stored in the visitor's browser localStorage only.
- No email notification is sent to the business.
- No server-side storage of contact requests exists.
- You have likely been missing customer inquiries without knowing.

Recommendation: Connect the contact form to a server-side API that sends email notifications and stores submissions securely.

MAJOR**8. Admin Password Reset Is Broken**

What this means: The "reset password" feature in the admin panel does not work. It calls the wrong endpoint and always fails.

Details:

- The reset function sends an empty current password, which the server rejects.
- Administrators cannot recover their password if forgotten through the admin panel.
- The system returns "Current and new passwords are required" every time.

Recommendation: Fix the password reset to use the correct server endpoint designed for password resets.

MAJOR**9. Cross-Origin Warning (Future Compatibility)**

What this means: Next.js is generating warnings about cross-origin requests. In a future update, this could prevent the website from loading properly.

Details:

- The development server logs show cross-origin request warnings.
- A future Next.js version will require explicit configuration to allow this.
- Not addressing this now will cause problems when the framework is updated.

Recommendation: Add the `allowedDevOrigins` configuration to the Next.js settings.

MODERATE — Should Be Fixed

MODERATE 10. Website Domain Is Hardcoded

What this means: The website code contains the domain "amaalsahari.com" written directly in many places. This means search engines and social media previews may point to the wrong address if the domain changes.

Details:

- SEO metadata, canonical URLs, and social sharing links all use the hardcoded domain.
- Google and other search engines will see conflicting information.
- If the site runs on a different domain (staging, Replit), SEO data will be wrong.

Recommendation: Use environment variables for the domain so it can be easily changed per environment.

MODERATE 11. Hardcoded WhatsApp Number

What this means: The footer contains a hardcoded fallback WhatsApp number that may not be correct.

Details:

- The number +201021454545 is used as a fallback in the footer.
- If the admin-configured number fails to load, visitors will contact the wrong number.

Recommendation: Remove the hardcoded fallback or make it configurable through the admin panel.

MODERATE 12. Footer Links May Break When Services Change

What this means: The footer has links to specific services that are written directly in the code. If you rename or reorganize services in the admin panel, these links will break.

Details:

- Service links in the footer are hardcoded, not dynamically generated.
- Changing service names in the admin panel won't update the footer.
- Visitors clicking broken footer links will see error pages.

Recommendation: Generate footer service links dynamically from the admin content.

MODERATE**13. Images Reload Every Time (Slow Performance)**

What this means: The website forces all images to reload from scratch on every page visit, even if they haven't changed. This makes the site slower and uses more bandwidth for your visitors.

Details:

- A timestamp is added to every image URL on each page load.
- This prevents browsers from caching images, causing repeated downloads.
- Visitors on slow connections will experience noticeably longer load times.

Recommendation: Only bust the cache when images actually change, not on every page load.

MODERATE**14. Unused Vercel Services Still Installed**

What this means: The website still includes software packages for Vercel (the previous hosting provider). These add unnecessary weight and will not function on Replit.

Details:

- @vercel/analytics and @vercel/blob packages are still in the project.
- These packages cannot connect to Vercel services from Replit.
- They add unnecessary code to your website bundle.

Recommendation: Remove the Vercel-specific packages and replace with alternatives if needed.

MINOR — Low Priority Improvements**MINOR****15. Missing Placeholder Image**

What this means: A placeholder image used as a fallback in several places does not exist.

Details:

- The file /placeholder.svg is referenced but missing.
- Components that fail to load images show a broken icon instead of a placeholder.

Recommendation: Add a simple placeholder image to improve the appearance when content images are unavailable.

MINOR

16. Service Pages Don't Show Proper 404 Errors

What this means: When someone visits a service page that doesn't exist, they see a basic inline message instead of the website's proper "page not found" design.

Details:

- Service pages use custom inline error messages instead of the standard 404 page.
- This creates an inconsistent experience for visitors.
- Search engines may not properly identify these as missing pages.

Recommendation: Use the built-in 404 page for missing services to improve consistency and SEO.

MINOR

17. Brief Language Flash for Arabic Users

What this means: Arabic-speaking users may see the website briefly appear in English before switching to Arabic.

Details:

- The language preference is loaded after the page renders.
- This causes a visible "flash" of English content for Arabic users.

Recommendation: Load the language preference earlier in the page lifecycle to prevent the flash.

MINOR

18. Leftover Files from Previous Hosting

What this means: The project contains over 30 documentation and script files from the previous Hostinger hosting setup that are no longer relevant.

Details:

- Files like HOSTINGER_SETUP.md, upload-to-hostinger.php, and various guides remain.
- These add clutter and may cause confusion during future maintenance.

Recommendation: Clean up unused documentation and hosting-specific files.

Recommended Action Plan

Phase 1 — Urgent (Security)

- !' Fix all 5 critical security issues to prevent unauthorized access.
- !' Add proper server-side authentication to admin API endpoints.
- !' Remove diagnostic endpoints or protect them behind login.
- !' Remove hardcoded credentials from the codebase.

Phase 2 — Essential (Functionality)

- !' Upload or configure all missing images.
- !' Fix the contact form to actually deliver messages.
- !' Repair the admin password reset feature.
- !' Configure email (SMTP) settings for notifications.

Phase 3 — Improvement (Quality)

- !' Fix hardcoded URLs and make them configurable.
- !' Remove unused Vercel packages.
- !' Improve image caching for better performance.
- !' Clean up leftover files from previous hosting.

This report was generated as part of the Vercel-to-Replit migration audit. All issues listed above were identified through automated scanning and manual code review. No changes have been made — this document is for review purposes only.